



إجراء الاستجابة لحوادث أمن المعلومات

بنك الآفاق الرقمية

تصنيف الوثيقة	سري للغاية - داخلي
مرجع الوثيقة	ISMS-DOC-A05-26-1
الإصدار	1.0
التاريخ	2026/09/12
معد الوثيقة	فريق الاستجابة للحوادث - إدارة أمن المعلومات
مالك الوثيقة	الأستاذة سارة الحربي - مدير أمن المعلومات (CISO)

سجل المراجعات

الإصدار	التاريخ	معد المراجعة	ملخص التغييرات
1.0	2026/09/12	فريق أمن المعلومات	الإصدار الأول للوثيقة

التوزيع

الاسم / الجهة	المسمى الوظيفي
جميع أعضاء فريق الاستجابة للحوادث	فريق الاستجابة للحوادث
عبد الله المحيسن	الإدارة العليا

الاعتماد

الاسم	المنصب	التوقيع	التاريخ
الدكتورة نورة القحطاني	الرئيس التنفيذي		
الأستاذة سارة الحربي	مدير أمن المعلومات (CISO)		

1 المقدمة

تُستخدم هذه الوثيقة عند وقوع حادث من أي نوع يؤثر على أمن المعلومات لدى بنك الأفاق الرقمية، وهي مصممة لضمان استجابة سريعة وفعالة ومنظمة لحوادث أمن المعلومات.

يجب استخدام الإجراءات الواردة في هذه الوثيقة كدليل استرشادي فقط عند التعامل مع أي حادث. لا يمكن التنبؤ بطبيعة الحادث وأثره الفعلي بدرجة يقين مطلقة، لذا من المهم استخدام قدر جيد من الحكمة العملية عند تحديد الإجراءات الواجب اتخاذها.

أهداف إجراء الاستجابة للحوادث هذا هي:

- تقديم نظرة عامة موجزة عن كيفية استجابة بنك الأفاق الرقمية لحادث يؤثر على أمن معلوماته.
 - تحديد الجهات المسؤولة عن الاستجابة للحادث وأدوارها ومسؤولياتها.
 - وصف التسهيلات المتاحة للمساعدة في إدارة الحادث.
 - تحديد كيفية اتخاذ القرارات المتعلقة باستجابة البنك للحادث.
 - توضيح كيفية إدارة التواصل داخل البنك ومع الأطراف الخارجية.
 - تقديم بيانات الاتصال بالأشخاص الرئيسيين والجهات الخارجية.
 - تحديد ما سيحدث بمجرد حل الحادث وإيقاف فرق الاستجابة.
- سيحصل جميع الموظفين المذكورين في هذه الوثيقة على نسخة منها يجب أن تكون متاحة لديهم عند الحاجة.
- سيتم التحقق من بيانات الاتصال وتحديثها ثلاث مرات على الأقل سنوياً. يجب إرسال أي تغييرات في بيانات الاتصال أو التفاصيل الأخرى ذات الصلة التي تطرأ خارج هذه المراجعات المجدولة إلى فريق أمن المعلومات في أقرب وقت ممكن بعد حدوث التغيير.

تُستخدم جميع المعلومات الشخصية التي يتم جمعها كجزء من إجراء الاستجابة للحوادث والواردة في هذه الوثيقة فقط لأغراض إدارة حوادث أمن المعلومات، وتخضع لتشريعات حماية البيانات ذات الصلة (نظام حماية البيانات الشخصية - سدايا).

2 مخطط سير الاستجابة للحوادث

يوضح الجدول التالي التسلسل العام لخطوات إجراء الاستجابة للحوادث لدى بنك الأفاق الرقمية:

#	المرحلة
1	اكتشاف الحادث والإبلاغ الأولي (عبر مركز العمليات الأمنية SOC أو الموظفين أو أطراف خارجية)
2	التقييم الأولي للأثر وتحديد الأولوية (عالية / متوسطة / منخفضة)
3	قرار قائد الفريق بتفعيل إجراء الاستجابة للحوادث من عدمه
4	تجميع فريق الاستجابة للحوادث (IRT) وتحديد الأدوار
5	الاحتواء لوقف تفاقم الحادث
6	الاستئصال ومعالجة السبب الجذري والثغرات المستغلّة
7	الاستعادة وإعادة الأنظمة لوضعها الطبيعي الآمن
8	الإخطار (الجهات التنظيمية، العملاء المتأثرون، الأطراف المعنية)

تشرح هذه الخطوات بمزيد من التفصيل في بقية هذا الإجراء.

3 اكتشاف الحادث وتحليله

قد يُكتشف الحادث في البداية بطرق متنوعة ومن مصادر مختلفة، حسب طبيعة الحادث وموقعه. قد تُكتشف بعض الحوادث ذاتياً عبر أدوات برمجية مستخدمة داخل البنك (مثل جدار الحماية أو أنظمة كشف التسلل) أو من خلال ملاحظة الموظفين لنشاط غير معتاد. وقد يُبلغ عن حوادث أخرى من طرف ثالث مثل عميل أو مورد أو جهة إنفاذ قانون تكون قد علمت بخرق ما.

ليس من غير المألوف وجود فارق زمني بين وقوع الحادث فعلياً واكتشافه الفعلي — كما تُظهر حادثة انتهاء شهادة TLS التي استمرت 4 ساعات قبل اكتشافها، أو حادثة الصلاحيات غير الملغاة التي ظلت قائمة لفترة غير معروفة قبل اكتشافها في مراجعة روتينية. أحد أهداف نظام إدارة أمن المعلومات هو تقليل هذه الفترة الزمنية. والعامل الأهم هو أن إجراء الاستجابة للحوادث يجب أن يبدأ في أسرع وقت ممكن بعد الاكتشاف حتى تكون الاستجابة فعالة.

3.1 تقييم الأثر

بمجرد اكتشاف الحادث، يجب إجراء تقييم أثر أولي (عادة من قبل مركز العمليات الأمنية SOC أو مكتب خدمة تقنية المعلومات) لتحديد الاستجابة المناسبة.

يجب أن يُقدّر هذا التقييم:

- مدى الأثر على البنية التحتية التقنية، بما يشمل الحواسيب والشبكات والمعدات والمواقع.
 - الأصول المعلوماتية التي قد تكون معرضة للخطر أو تم اختراقها.
 - المدة المحتملة للحادث، أي متى يُحتمل أنه بدأ.
 - وحدات الأعمال المتأثرة ومدى الأثر عليها.
 - مؤشر أولي على السبب المحتمل للحادث.
- يجب توثيق هذه المعلومات بحيث يتوفر فهم واضح ومرتب زمنياً للوضع أثناء تطوره للاستخدام الحالي والمراجعة اللاحقة.

3.2 تحديد أولوية الحادث

استناداً إلى تقييم الأثر، تُمنح كل حادثة أولوية (عالية، متوسطة، أو منخفضة). يوضح الجدول التالي الإرشادات المستخدمة لتحديد الأولوية، مع أمثلة مأخوذة من واقع بنك الأفاق الرقمية:

الأولوية	الوصف والأمثلة
عالية	تعطل فعلي أو محتمل كبير في أعمال البنك. أمثلة: انتشار برمجية فدية عبر الشبكة، وصول غير مصرح به لكميات كبيرة من بيانات العملاء السرية، تعطل منصة آفاق نت نتيجة هجوم حجب خدمة محتمل.
متوسطة	تعطل موضعي يؤثر على عدة مجالات أعمال. أمثلة: عدم توفر نظام واحد (مثل نظام كشف الاحتيال)، بطء ملحوظ في الشبكة، فقدان جهاز حاسوب محمول مشفر.
منخفضة	إزعاج موضعي يؤثر على مستخدم واحد. أمثلة: مخالفة بسيطة لسياسة أمن المعلومات، تنبيه فيروس على جهاز واحد، مشاركة كلمة مرور لنظام منخفض الحساسية.

نتيجة لهذا التحليل الأولي، يمتلك مكتب خدمة تقنية المعلومات أو أي عضو من فريق الإدارة صلاحية التواصل مع قائد فريق الاستجابة للحوادث في أي وقت لطلب تقييم ما إذا كان ينبغي تفعيل إجراء الاستجابة لحوادث أمن المعلومات. من المرجح أن ينطبق ذلك على جميع الحوادث ذات الأولوية العالية، والحوادث متوسطة الأولوية حيثما رُئي ذلك مناسباً.

4 تفعيل إجراء الاستجابة للحوادث

بمجرد إبلاغه بالحادث، يجب على قائد الفريق تحديد ما إذا كان حجم الحادث وأثره الفعلي أو المحتمل يُبرر تفعيل إجراء الاستجابة للحوادث وتشكيل فريق الاستجابة للحوادث (IRT).

سيكون قد أُجري تقييم أثر أولي من قبل مكتب خدمة تقنية المعلومات، لكن الإرشادات الإضافية لقائد الفريق بشأن ما إذا كان ينبغي بدء استجابة رسمية لأي حادث معين تشمل الحالات التالية:

- وجود فقدان فعلي أو محتمل جوهري لمعلومات مصنفة.
- وجود تعطل فعلي أو محتمل جوهري لعمليات الأعمال.
- وجود خطر جوهري على سمعة البنك.
- أي موقف آخر قد يسبب أثراً جوهرياً على البنك.

في حال الخلاف أو عدم اليقين بشأن تفعيل الاستجابة، يكون قرار قائد الفريق نهائياً.

إذا تقرر عدم تفعيل الإجراء، يجب وضع خطة للسماح باستجابة على مستوى أدنى للحوادث ضمن القنوات الإدارية الاعتيادية. قد يشمل ذلك تفعيل إجراءات ذات صلة على المستوى المحلي (مثل إجراء الفرع أو القسم المعني).

إذا استدعى الحادث تفعيل إجراء الاستجابة، سيبدأ قائد الفريق في تجميع فريق الاستجابة للحوادث.

5 تشكيل فريق الاستجابة للحوادث

بمجرد اتخاذ قرار تفعيل إجراء الاستجابة للحوادث، يتأكد قائد الفريق (أو نائبه) من التواصل مع جميع أصحاب الأدوار (أو نوابهم في حال تعذر الوصول لأصحاب الأدوار الرئيسيين)، وإبلاغهم بطبيعة الحادث، وطلب التجمع في الموقع المناسب أو حضور اجتماع افتراضي.

الاستثناء هو ضابط ارتباط الحادث الذي سيطلب منه التوجه إلى موقع الحادث (إن اختلف وكان ذلك مناسباً) لبدء جمع المعلومات اللازمة لتقييم الحادث الذي سيجريه فريق الاستجابة، بحيث يمكن تحديد الاستجابة المناسبة.

5.1 أعضاء فريق الاستجابة للحوادث

يتكون فريق الاستجابة للحوادث عموماً من الأشخاص التالية أدوارهم ونوابهم، مع العلم أن التشكيل الفعلي للفريق سيختلف حسب طبيعة الحادث:

الدور/مجال العمل	صاحب الدور الرئيسي	النائب
قائد الفريق	مدير أمن المعلومات (CISO) - الأستاذة سارة الحربي	مدير تقنية المعلومات (CIO)
منسق الفريق	رئيس فريق حوكمة أمن المعلومات	أحد أعضاء فريق الاستجابة للحوادث
ضابط ارتباط الحادث	رئيس فريق الاستجابة للحوادث	أحد محلي مركز العمليات الأمنية (SOC)
تقنية المعلومات	مدير البنية التحتية والشبكات	مدير قواعد البيانات
العمليات المصرفية	مدير العمليات المصرفية	مدير الخدمات المصرفية للأفراد
إدارة المرافق	مدير إدارة المرافق والخدمات العامة	مسؤول الأمن المادي بالمقر الرئيسي
السلامة والصحة المهنية	مسؤول السلامة بإدارة المرافق	-
الموارد البشرية	مدير الموارد البشرية - الأستاذ خالد الشمري	رئيس قسم شؤون الموظفين
استمرارية الأعمال	مسؤول استمرارية الأعمال بإدارة تقنية المعلومات	مدير مركز التعافي من الكوارث (جدة)
الاتصالات (العلاقات العامة والإعلام)	مدير التسويق وتجربة العميل	المتحدث الرسمي المعتمد
الشؤون القانونية والتنظيمية	الأستاذة ليلى الدوسري - مدير الشؤون القانونية	مسؤول الالتزام والحوكمة

بيانات الاتصال الخاصة بما سبق مدرجة في الملحق أ من هذه الوثيقة.

5.2 الأدوار والمسؤوليات

5.2.1 قائد الفريق

- يقرر ما إذا كان سيتم بدء الاستجابة.
- يُجمع فريق الاستجابة للحوادث.
- الإدارة الشاملة لفريق الاستجابة للحوادث.
- يعمل كحلقة وصل مع مجلس الإدارة وأصحاب المصلحة رفيعي المستوى الآخرين.
- صاحب القرار النهائي في حالات الخلاف.

5.2.2 منسق الفريق

- يدعم فريق الاستجابة للحوادث.
- ينسق الموارد داخل مركز القيادة/غرفة العمليات.
- يُحضّر للاجتماعات ويسجل الإجراءات والقرارات.
- يُطلع أعضاء الفريق على آخر مستجدات الوضع عند عودتهم لمركز القيادة.
- يُيسّر التواصل عبر البريد الإلكتروني أو الهاتف أو وسائل أخرى.
- يراقب مصادر المعلومات الخارجية مثل الأخبار.

5.2.3 ضابط ارتباط الحادث

- يحضر إلى موقع الحادث في أسرع وقت ممكن.
- يُقيّم مدى الحادث وأثره.
- يقدم رواية مباشرة عن الوضع لفريق الاستجابة.
- يتواصل باستمرار مع فريق الاستجابة لتقديم التحديثات والإجابة عن أي أسئلة لازمة لاتخاذ القرار.

5.2.4 تقنية المعلومات

- يقدم مدخلات حول القضايا التقنية.
- يساعد في تقييم الأثر.

5.2.5 العمليات المصرفية

- يساهم في اتخاذ القرار استناداً لمعرفته بعمليات البنك ومنتجاته وخدماته.
- يُطلع أعضاء الفريق الآخرين على القضايا التشغيلية.
- يساعد في تقييم الأثر المحتمل على عملاء البنك.

5.2.6 إدارة المرافق

- يتعامل مع جوانب الأمن المادي والوصول.
- يوفر حضوراً أمنياً عند الحاجة.

5.2.7 السلامة والصحة المهنية

- يُقيّم الخطر على حياة وسلامة الأفراد.
- يضمن الوفاء بالمسؤوليات القانونية للسلامة والصحة المهنية في جميع الأوقات.
- يتواصل مع خدمات الطوارئ مثل الشرطة والدفاع المدني والطبية.

5.2.8 الموارد البشرية

- يُقيّم ويُقدّم المشورة بشأن سياسة الموارد البشرية وأمور عقود العمل.
- يمثل مصالح موظفي البنك.
- يقدم المشورة بشأن قضايا الكفاءة والإجراءات التأديبية.

5.2.9 استمرارية الأعمال

- يقدم المشورة بشأن خيارات استمرارية الأعمال.
- يُفعّل خطط استمرارية الأعمال عند الحاجة، بما يشمل التحويل لمركز التعافي من الكوارث في جدة.

5.2.10 الاتصالات (العلاقات العامة والإعلام)

- مسؤول عن ضمان فعالية الاتصالات الداخلية.
- يقرر مستوى وتكرار ومحتوى التواصل مع الأطراف الخارجية مثل الإعلام.
- يحدد نهج إبقاء الأطراف المتأثرة على اطلاع (مثل العملاء والمساهمين).

5.2.11 الشؤون القانونية والتنظيمية

- يقدم المشورة بشأن ما يجب فعله لضمان الامتثال للقوانين ذات الصلة والأطر التنظيمية (ساما، سدايا).
- يُقيّم التبعات القانونية الفعلية والمحتملة للحادث والإجراءات اللاحقة.
- يتواصل مع شركة التأمين السيبراني لتقييم المطالبة والحصول على موارد إضافية.

5.3 مصفوفة RACI

يوضح الجدول التالي من يكون مسؤولاً عن التنفيذ (R)، أو مسؤولاً نهائياً (A)، أو يُستشار (C)، أو يُبلغ (I) في مختلف مراحل الإجراء:

المهمة	قائد الفريق	المنسق	ضابط الارتباط	تقنية المعلومات	العمليات	المرافق	السلامة	الموارد البشرية	استمرارية الأعمال	الاتصالات	القانونية	الموظفون
اكتشاف الحادث	A	R	R	I	C	R	R	I	I	I	I	R
تحليل الحادث	A	R	R	C	C	C	C	I	C	I	I	I
تشكيل فريق الاستجابة	A	R	C	C	C	C	C	C	C	C	C	I
الاحتواء	A	R	R	C	R	R	R	I	I	I	I	I
الاستئصال	A	R	R	C	R	R	R	I	C	I	I	I
الاستعادة	R	C	C	C	A	R	R	C	C	I	C	I
التواصل الداخلي	A	C	C	C	C	C	C	R	C	R	C	I
التواصل الخارجي	A	C	C	C	C	C	C	C	C	R	C	I
الإخطار (مثل ساما/سدايا)	A	C	C	R	C	C	C	C	I	C	R	I
تقرير الحادث	A	R	C	C	C	C	C	C	C	I	C	C
المراجعة بعد الحادث	A	R	C	C	C	C	C	C	C	C	C	C

مفتاح الاختصارات: قائد الفريق، المنسق، ضابط الارتباط، تقنية المعلومات، العمليات المصرفية، إدارة المرافق، السلامة والصحة المهنية، الموارد البشرية، استمرارية الأعمال، الاتصالات، الشؤون القانونية، الموظفون.

5.4 إدارة الحادث ومراقبته والتواصل بشأنه

بمجرد تحديد استجابة مناسبة للحادث، يحتاج فريق الاستجابة إلى القدرة على إدارة الاستجابة الشاملة ومراقبة حالة الحادث وضمان تواصل فعال على جميع المستويات.

يجب عقد اجتماعات دورية لفريق الاستجابة بالتردد المناسب الذي يحدده قائد الفريق. يوجد جدول أعمال قياسي لهذه الاجتماعات في الملحق ج. الغرض من هذه الاجتماعات ضمان إدارة موارد إدارة الحادث بفعالية واتخاذ القرارات الرئيسية بسرعة بناءً على معلومات كافية. سيُدوّن منسق الفريق محضراً لكل اجتماع.

سيقدم ضابط ارتباط الحادث تحديثات لفريق الاستجابة بالتردد الذي يحدده قائد الفريق، وينبغي تنسيق هذه التحديثات مع اجتماعات الفريق بحيث تتوفر أحدث المعلومات في كل اجتماع.

5.5 إجراءات التواصل

من الضروري الحفاظ على تواصل فعال بين جميع الأطراف المشاركة في الاستجابة للحادث. حسب الموقف، قد تكون وسيلة التواصل الافتراضية أثناء الحادث وجاهية أو عبر الهاتف أو عبر أدوات التعاون (مثل Microsoft Teams)، وفق ما يحدده قائد الفريق. لا يجب استخدام البريد الإلكتروني إلا بإذن من فريق الاستجابة للحادث.

يجب اتباع الإرشادات التالية في جميع الاتصالات:

- التزم الهدوء وتجنب المحادثات المطولة.
 - أبلغ أعضاء الفريق الداخليين بضرورة إحالة طلبات المعلومات إلى فريق الاستجابة.
 - إذا ردّ على المكالمات شخص غير جهة الاتصال المقصودة: اسأل عن إمكانية التواصل معها في مكان آخر، وإذا تعذر ذلك اترك رسالة لطلب التواصل على رقم محدد، ولا تُفصح عن تفاصيل الحادث.
 - وثّق دائماً تفاصيل وقت المكالمات والردود والإجراءات.
- يجب تسجيل جميع الاتصالات بدقة ووضوح، لأن السجلات قد تكون مطلوبة كجزء من أي إجراء قانوني لاحق.

5.5.1 التواصل الخارجي

حسب طبيعة الحادث، قد تكون هناك أطراف خارجية متعددة سيتم التواصل معها أثناء الاستجابة. من المهم إدارة المعلومات المُفصح عنها للأطراف الثالثة بحيث تكون دقيقة وفي الوقت المناسب. المكالمات التي لا تأتي من جهات مشاركة مباشرة في الاستجابة للحادث (مثل الإعلام) يجب إحالتها لعضو الاتصالات في فريق الاستجابة.

قد تكون هناك أطراف خارجية غير مشاركة مباشرة في الحادث لكنها قد تتأثر به وتحتاج إلى إخطارها بذلك، منها:

- العملاء
 - الموردون
 - المساهمون
 - الجهات التنظيمية (ساما، سدايا)
 - الجهات الرقابية
 - شركات التأمين
- يجب على عضو الاتصالات في فريق الاستجابة إعداد قائمة بهذه الأطراف المعنية وتحديد الرسالة التي ستُقدّم لهم. توجد قائمة ببعض الجهات الخارجية في الملحق ب.

قد تتصل أطراف معنية لم يتم إخطارها من قبل فريق الاستجابة للاستفسار عن الحادث وآثاره. يجب تسجيل هذه المكالمات في سجل الرسائل وإحالتها لعضو الاتصالات في الفريق.

5.5.2 التواصل مع الإعلام

بشكل عام، ستكون استراتيجية التواصل مع الإعلام هي إصدار التحديثات عبر الإدارة العليا. لا يجوز لأي موظف إجراء مقابلة مع الإعلام إلا بتصريح مسبق من فريق الاستجابة للحوادث.

الواجهة المفضلة للتعامل مع الإعلام هي إصدار بيانات صحفية مُعدّة مسبقاً. في ظروف استثنائية، سيعقد مؤتمر صحفي للإجابة عن الأسئلة المتعلقة بالحدث وأثاره. تقع على عاتق عضو الاتصالات في فريق الاستجابة مسؤولية ترتيب مكان هذه المؤتمرات والتنسيق مع الصحافة الراغبة في الحضور.

عند صياغة بيان للإعلام، يجب مراعاة الإرشادات التالية:

- يجب حماية المعلومات الشخصية دائماً.
 - التزم بالحقائق ولا تُخمن بشأن الحادث أو سببه.
 - تأكد من الحصول على المشورة القانونية قبل إصدار أي بيانات.
 - حاول استباق الأسئلة التي يُتوقع طرحها بشكل معقول.
 - أكد أنه تم تفعيل استجابة مُعدّة مسبقاً وأن كل ما يمكن فعله يُنفذ فعلياً.
- سُيُعين الموظفون التالية أدوارهم كمتحدثين رسميين باسم البنك في حال طُلب تقديم مزيد من المعلومات، مثل مؤتمر صحفي:

نطاق الحادث	الوظيفة	الاسم/الدور
منخفض	الاتصالات المؤسسية	عضو الاتصالات في فريق الاستجابة
متوسط	رئيس الاتصالات المؤسسية	مدير التسويق وتجربة العميل
عالٍ	الرئيس التنفيذي	الدكتورة نورة القحطاني

سيعتمد المتحدث الأنسب على حجم الحادث وأثره على العملاء والموردين والجمهور وأصحاب المصلحة الآخرين.

6 احتواء الحادث واستنصاه واستعادته وإخطاره

يصف هذا القسم الخطوات الرئيسية لإدارة الحادث. تتوفر إجراءات وخطط إضافية لتغطية تفاصيل هذه الخطوات لأنواع معينة من الحوادث، مثل الفدية وحجب الخدمة وخرق البيانات.

6.1 الاحتواء

الخطوة الأولى هي محاولة منع تفاقم الحادث، أي احتواؤه. في حالة انتشار فيروس، قد يستلزم ذلك فصل الأجزاء المتأثرة من الشبكة؛ وفي حالة هجوم اختراق، قد يشمل ذلك تعطيل ملفات تعريف أو منافذ معينة على جدار الحماية أو حتى فصل الشبكة الداخلية عن الإنترنت بالكامل. ستعتمد الإجراءات المحددة على ظروف الحادث.

ملاحظة: إذا كان من المرجح أن يلزم جمع أدلة رقمية ستُستخدم لاحقاً في المحكمة، يجب اتخاذ احتياطات لضمان بقاء هذه الأدلة مقبولة قانونياً. هذا يعني عدم تغيير البيانات ذات الصلة عمداً أو عن طريق الخطأ (مثل تشغيل جهاز محمول من وضع السكون). يُوصى بالحصول على استشارة متخصصة في هذه المرحلة — راجع جهات الاتصال في الملحق ب.

خصوصاً (وليس حصراً) عند الاشتباه بوجود فعل إجرامي، يجب الاحتفاظ بسجلات دقيقة للإجراءات المتخذة والأدلة التي تم جمعها وفق إرشادات الأدلة الجنائية الرقمية. المبادئ الرئيسية لهذه الإرشادات هي:

المبدأ 1: لا تُغيّر أي بيانات. إذا أدى أي إجراء إلى تغيير البيانات الموجودة على النظام ذي الصلة بأي شكل، فسيؤثر ذلك على أي قضية قانونية لاحقة.

المبدأ 2: لا تصل إلى البيانات الأصلية إلا في ظروف استثنائية. سيستخدم مختص مدرب أدوات لأخذ نسخة طبق الأصل من أي بيانات محفوظة، سواء على قرص صلب أو ذاكرة فلاش أو بطاقة SIM. تجرى جميع التحليلات على النسخة، ولا يجب لمس الأصل إلا في ظروف استثنائية.

المبدأ 3: احتفظ دائماً بمسار تدقيق لكل ما تم فعله. تقوم الأدوات الجنائية بذلك تلقائياً، وينطبق ذلك أيضاً على أول الحاضرين إلى موقع الحادث؛ يُشجّع التقاط الصور ومقاطع الفيديو طالما لم يتم لمس أي شيء للقيام بذلك.

المبدأ 4: يجب على الشخص المسؤول التأكد من اتباع هذه الإرشادات.

قبل وصول المختص، يجب جمع معلومات أساسية قد تشمل: صوراً أو مقاطع فيديو للرسائل أو المعلومات ذات الصلة، سجلات مكتوبة يدوياً لتسلسل الحادث زمنياً، الوثائق الأصلية (بما يشمل سجلات من وجدها ومتى وأين)، وتفاصيل أي شهود.

بمجرد جمعها، تُحفظ الأدلة في مكان آمن لا يمكن العبث بها فيه، مع إنشاء سلسلة حيازة رسمية (Chain of Custody). قد تكون الأدلة مطلوبة للتحليل اللاحق لسبب الحادث، أو كدليل جنائي في إجراءات قضائية جنائية أو مدنية، أو لدعم أي مفاوضات تعويض مع موردي البرمجيات أو الخدمات.

بعد ذلك، يجب تكوين صورة واضحة لما حدث، وتحديد مدى الحادث وتبعاته قبل اتخاذ أي إجراء احتواء. يمكن فحص سجلات التدقيق (Audit Logs) لتجميع تسلسل الأحداث، مع الحرص على استخدام نسخ آمنة من السجلات لم يتم العبث بها فقط.

6.2 الاستئصال

يجب أن تمر الإجراءات اللازمة لإصلاح الضرر الناجم عن الحادث، مثل حذف البرمجيات الخبيثة، عبر عملية إدارة التغيير (على الأرجح كتغيير طارئ). يجب أن تهدف هذه الإجراءات إلى معالجة السبب الحالي ومنع تكرار الحادث. يجب تحديد أي ثغرات تم استغلالها كجزء من الحادث — كما حدث في تحديد الثغرات الثلاث عالية الخطورة في تطبيق أفاق بلس بعد فحص الثغرات الأخير.

حسب نوع الحادث، قد لا يكون الاستئصال ضرورياً في بعض الأحيان.

6.3 الاستعادة

خلال مرحلة الاستعادة، يجب إعادة الأنظمة إلى حالتها قبل وقوع الحادث، مع تنفيذ الإجراءات اللازمة لمعالجة أي ثغرات تم استغلالها كجزء من الحادث. قد يشمل ذلك أنشطة مثل تثبيت التحديثات، وتغيير كلمات المرور، وتحسين الخوادم، وتعديل الإجراءات — كما جرى فعلياً بعد حادثة انقطاع الخدمة بمراجعة إعدادات جدار الحماية وتحسين عملية التغييرات.

6.4 الإخطار

يُعد إخطار حادث أمن المعلومات وما ينتج عنه من فقدان للبيانات مسألة حساسة يجب التعامل معها بعناية وبموافقة إدارية كاملة. سيقدر فريق الاستجابة للحادث، استناداً إلى المشورة القانونية والخبرات المتخصصة الأخرى وأكبر قدر ممكن من الفهم لأثر الحادث، ما هو الإخطار المطلوب، ومتى يجب أن يتم، والشكل الذي سيتخذه.

يلتزم بنك الآفاق الرقمية دائماً بالامتثال الكامل للمتطلبات القانونية والتنظيمية المعمول بها بشأن إخطار الحادث، بما يشمل الإبلاغ الفوري عن الحادث السيبرانية الكبرى للبنك المركزي السعودي (ساما) وإخطار هيئة البيانات والذكاء الاصطناعي (سداء) في حال تأثر بيانات شخصية، أسوة بما تم فعلياً في حادثة فقدان الجهاز المحمول التي أدت إلى إخطار الجهات المختصة والعلماء المتأثرين.

سيُقيم البنك بعناية أي عروض تُقدّم للأطراف التي قد تتأثر بالحادث، مثل خدمات مراقبة سرقة الهوية للعملاء المتأثرين.

قد تكون السجلات التي تُجمع كجزء من الاستجابة للحادث مطلوبة كجزء من أي تحقيقات لاحقة من قبل الجهات التنظيمية ذات العلاقة، وسيتعاون بنك الآفاق الرقمية بشكل كامل مع هذه الإجراءات.

7 النشاط بعد الحادث

سيقدر قائد الفريق، استناداً إلى أحدث المعلومات من ضابط ارتباط الحادث وأعضاء الفريق الآخرين، النقطة التي يجب عندها إيقاف أنشطة الاستجابة وإيقاف فريق الاستجابة للحادث. لاحظ أن الاستعادة وتنفيذ الخطط قد يستمران بعد هذه النقطة لكن تحت رقابة إدارية أقل رسمية.

سيعتمد هذا القرار على تقدير قائد الفريق لكن يجب أن يستند إلى المعايير التالية:

- تمت معالجة الوضع بالكامل أو أصبح مستقراً بشكل معقول.
 - تباطأت وتيرة تغيير الوضع لدرجة أنه لم يعد هناك حاجة لقرارات كثيرة.
 - الاستجابة المناسبة قيد التنفيذ بشكل جيد وخطط الاستعادة تسير وفق الجدول الزمني.
 - انخفضت درجة المخاطرة على البنك إلى مستوى مقبول.
 - تم الوفاء بالمسؤوليات القانونية والتنظيمية الفورية.
- إذا كانت الاستعادة من الحادث مستمرة، يجب على قائد الفريق تحديد الإجراءات التالية الواجب اتخاذها، وقد تشمل: عقد اجتماعات أقل تكراراً لفريق الاستجابة (أسبوعياً مثلاً حسب الظروف)، إبلاغ جميع الأطراف المعنية بإيقاف فريق الاستجابة، ضمان تأمين جميع وثائق الحادث، وطلب عودة الموظفين غير المشاركين في العمل الإضافي إلى مهامهم الاعتيادية.

يجب تسجيل جميع الإجراءات المتخذة كجزء من عملية الإيقاف. بعد توجيه فريق الاستجابة للتوقف، سيعقد قائد الفريق جلسة استخلاص لجميع الأعضاء، يُفضّل خلال 24 ساعة. سيراجع فريق الاستجابة السجلات ذات الصلة بالحادث للتأكد من أنها تعكس الأحداث الفعلية وتمثل سجلاً كاملاً ودقيقاً للحادث.

سيتم تسجيل أي تعليقات أو ملاحظات فورية من الفريق. ستُعقد مراجعة أكثر رسمية بعد الحادث في وقت تحدده الإدارة العليا وفقاً لحجم الحادث وطبيعته، ويجب أن تُستخلص منها الدروس ونقاط التحسين وتُدرج ضمن سجل تحسينات نظام إدارة أمن المعلومات.

8 الملحق أ: جدول اتصال الاستجابة الأولية

يجب استخدام الجدول أدناه لتسجيل محاولات التواصل الناجحة وغير الناجحة مع أعضاء فريق الاستجابة للحوادث. ملاحظة: لعمود النتيجة، اختر من بين "تم التواصل"، "لا يوجد رد"، "تم ترك رسالة"، "يتعذر الوصول".

الاسم	الدور في الخطة	هاتف المكتب	الجوال	التاريخ/الوقت	النتيجة
مدير أمن المعلومات (CISO) - الأستاذة سارة الحربي	قائد الفريق				
رئيس فريق حوكمة أمن المعلومات	منسق الفريق				
رئيس فريق الاستجابة للحوادث	ضابط ارتباط الحادث				
مدير البنية التحتية والشبكات	تقنية المعلومات				
مدير العمليات المصرفية	العمليات المصرفية				
مدير إدارة المرافق والخدمات العامة	إدارة المرافق				
مسؤول السلامة بإدارة المرافق	السلامة والصحة المهنية				
مدير الموارد البشرية - الأستاذ خالد الشمري	الموارد البشرية				
مسؤول استمرارية الأعمال بإدارة تقنية المعلومات	استمرارية الأعمال				
مدير التسويق وتجربة العميل	الاتصالات (العلاقات العامة والإعلام)				
الأستاذة ليلي الدوسري - مدير الشؤون القانونية	الشؤون القانونية والتنظيمية				

9 الملحق ب: جهات اتصال خارجية مفيدة

يوضح الجدول التالي بيانات اتصال الأطراف الثالثة التي قد تكون مفيدة حسب طبيعة الحادث:

الجهة	جهة الاتصال	الهاتف	البريد الإلكتروني
البنك المركزي السعودي (ساما) - قسم الإبلاغ عن الحوادث السيبرانية			
الهيئة الوطنية للأمن السيبراني (NCA)			
هيئة البيانات والذكاء الاصطناعي (سدايا)			
شركة استشارية للتحقيق الجنائي الرقمي (Forensics)			
استشاري فحص الثغرات الخارجي المتعاقد معه			
مزود خدمة الإنترنت (شركة الاتصالات السعودية)			
مزود الخدمة السحابية (AWS) - الدعم الأمني			
شركة التأمين السيبراني			
جهات إنفاذ القانون (النجدة الأمنية / مكافحة الجرائم المعلوماتية)			
مستشار العلاقات الإعلامية			

10 الملحق ج: جدول أعمال اجتماع فريق الاستجابة القياسي

يُوصى باستخدام جدول الأعمال القياسي التالي لاجتماعات فريق الاستجابة للحوادث.

الحقل	التفاصيل
الحضور	جميع أعضاء فريق الاستجابة للحوادث
الموقع	مركز القيادة بالمقر الرئيسي / غرفة العمليات / اجتماع عبر الإنترنت
التكرار	كل أربع ساعات (أو حسب ما يحدده قائد الفريق)
يرأس الاجتماع	قائد الفريق
يُدوّن المحضر	منسق الفريق

بنود جدول الأعمال:

- الإجراءات من الاجتماع السابق
- تحديث حالة الحادث
- القرارات المطلوبة
- توزيع المهام
- التواصل الداخلي
- التواصل الخارجي
- إيقاف فريق الاستجابة
- أي موضوعات أخرى